Clase 15 · Políticas de seguridad

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · jueves 22 oct 2026 · Tema 4 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

4.1 Qué es una política de seguridad

Definiciones

Política de seguridad: conjunto de reglas y procedimientos que indican cómo se van a cumplir los objetivos de seguridad en una organización.

Política de seguridad informática (PSI, también PCC o PS): subconjunto de las políticas organizacionales; son las reglas que dirigen y regulan la manipulación, el resguardo y la dirección de los bienes e infraestructura informática.

Políticas organizacionales	Políticas de seguridad informática
Reglas generales de la organización (horarios, conducta, procesos)	Reglas específicas para la infraestructura tecnológica y los datos
Marco que respalda a las demás	Subconjunto: no tiene sentido sin el marco organizacional

- Deben existir **por escrito**, en papel o en digital (intranet o internet): el personal viene de fuera y no conoce las "reglas no escritas".
- El problema actual no es que falten reglamentos, sino que **no se obliga a cumplirlos** o no hay quién vigile su ejecución (entidad interna o externa).

4.2 Cuándo se actualizan

Regla de examen

Las políticas tienen vigencia continua y se actualizan **por cambios significativos, no por calendario**. Fijar periodos rígidos (semanal, semestral, anual, por lustro) es un error metodológico.

Cambios significativos que la profesora enumeró:

- **Cambio de giro** de la organización.
- **Nueva tecnología:** cuando la Facultad de Ingeniería no tenía red inalámbrica y hubo que regular el Wi-Fi; hoy, la falta de regulación del uso de la **inteligencia artificial**.
- **Fusión o separación** de áreas.
- **Creación o modificación** de puestos y actividades.
- **Contingencias** o eventos extraordinarios: el examen de admisión en línea de la UNAM obligó a reestructurar procesos.

Al actualizar se adaptan solo los artículos afectados; no se tira todo el reglamento.

4.3 Marco normativo, lenguaje y a quién aplican

- **Jerarquía normativa:** todo reglamento interno (p. ej. el del Laboratorio de Redes y Seguridad) cita y se subordina a normas superiores: legislación universitaria y, arriba, la ley del país. En la Facultad de Ingeniería el reglamento lo revisan y aprueban la administración de cómputo y la comisión de laboratorios.
- **Lenguaje incluyente:** "el alumnado", "la persona usuaria", "el personal docente", "el personal administrativo".
- **Quién "labora":** las políticas aplican a todas las personas que laboran en el recinto, y laborar **no es estar en nómina**: incluye servicio social, becarios, auditores externos e invitados que hagan alguna actividad.

Error común: copiar el reglamento de otra organización sin adaptarlo a la problemática propia.

4.4 Objetivos, ventajas y sanciones

Las políticas regulan el comportamiento de las personas y la tecnología, y definen activos, tareas y reconocimientos. Pueden incluir **incentivos** (bono de puntualidad, acceso al comedor).

Sanciones (de menor a mayor)	Límite
Amonestación verbal → oficios o comunicados (en la FI, cartas de extrañamiento al expediente) → suspensión → baja	Ninguna puede contravenir la **Constitución**: nada de castigos físicos ni actos discriminatorios

Ventajas de tener políticas:

- Normar licitaciones y adquisiciones.
- Exigir capacitación periódica al personal nuevo o promovido.
- Llegar preparados a las auditorías sin improvisar.
- Eliminar la excusa de "es que yo no sabía".

Error común: no prohibir por escrito algo evidente (comer o beber sobre los equipos) y luego no poder sancionarlo.

4.5 Los seis principios para redactar políticas

Principio	Qué exige
Autorización	Decir con claridad qué está permitido y qué prohibido, y en qué contexto. No "no corro", sino "en caso de eventualidades o emergencias, se prohíbe correr".
Mínimo privilegio	Permisos y accesos limitados a lo que cada puesto necesita.
Separación de funciones	Las tareas críticas no recaen en una sola persona; se definen suplentes (un administrador de red de respaldo) para que una enfermedad o renuncia no paralice la operación.
Redundancia	Obligar a respaldar la información: cómo, cada cuánto y quiénes son responsables.

Reducción del riesgo	Normas preventivas; si dice "solo personal autorizado", definir quién cumple el perfil.
Responsabilidad individual	Debe estar en **todas** las políticas: la regla dice a qué persona o rol le toca.

> **Error de redacción típico**
>
> Oraciones sin sujeto: "no corro, no grito, no empujo", "a las 8 pm se cierra el recinto", "mantener limpia la casa". No dicen a quién aplican ni quién debe actuar, y dejan huecos que usan usuarios o atacantes para evadir su responsabilidad.

Avisos

- La profesora revisará las reglas que redactaron para señalar errores contra los principios (sin entrega nueva con fecha).
- Pidió los correos de todos los integrantes de cada equipo para contestar de forma unificada.

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Qué es. Política de seguridad = reglas y procedimientos para cumplir los objetivos de seguridad. La PSI es un **subconjunto** de las políticas organizacionales, dirigido a la infraestructura informática y los datos. Siempre por escrito; el problema real es hacerlas cumplir.

> **Actualización (examen)**
>
> Por **cambios significativos**, nunca por calendario: cambio de giro, nueva tecnología (Wi-Fi, IA), fusión/separación de áreas, nuevos puestos, contingencias (admisión en línea UNAM).

A quién aplican. A todos los que **laboran** en el recinto: no solo nómina, también servicio social, becarios, auditores externos e invitados. Se subordinan a normas superiores y usan lenguaje incluyente.

Sanciones. Amonestación verbal → oficios/cartas de extrañamiento → suspensión → baja; nunca contra la Constitución. También puede haber incentivos.

Seis principios	En una línea
Autorización	Qué se permite/prohíbe y en qué contexto
Mínimo privilegio	Solo el acceso que el puesto necesita
Separación de funciones	Nadie hace solo lo crítico; hay suplentes
Redundancia	Respaldos: cómo, cada cuánto, quién
Reducción del riesgo	Prevenir y definir perfiles ("autorizado" = quién)
Responsabilidad individual	En **todas** las políticas; cada regla tiene sujeto